



Práctica 2 - Parte 1

Materia:

Seguridad en el Desarrollo de Aplicaciones

Profesor:

Gerardo Ramírez Villarreal

Grupo:

IDGS17

Alumn@:

Sánchez Palomino Nuvia Yasmin

Matricula:

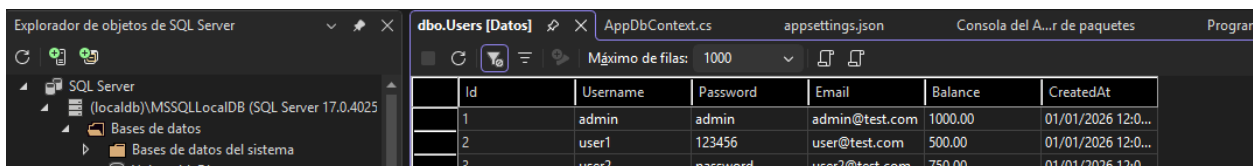
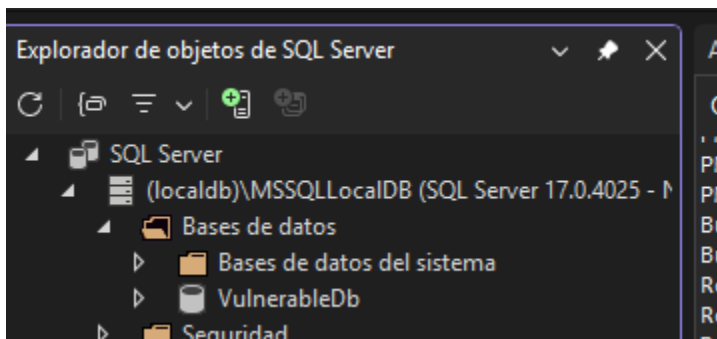
2023371105

SEGG-U1-P2A_Practica_Config_Inicial.pdf

Compilación de VulnerableApp

```
Salida
Mostrar salida de: Compilación
1>----- Se ha iniciado la ejecución del comando Compilar; proyecto: VulnerableApp, configuración: Debug -----
1> VulnerableApp -> C:\practicass seda\VulnerableApp\bin\Debug\net10.0\VulnerableApp.dll
===== Compilar: 1 correcto, 0 erróneo, 0 actualizado, 0 omitido =====
La compilación Compilar se ejecutó correctamente.
```

```
Done.
PM> dotnet ef migrations add InitialCreate
Build started...
Build succeeded.
Done. To undo this action, use 'ef migrations remove'
PM> dotnet ef database update
Build started...
Build succeeded.
```



Id	Username	Password	Email	Balance	CreatedAt
1	admin	admin	admin@test.com	1000.00	01/01/2026 12:0...
2	user1	123456	user@test.com	500.00	01/01/2026 12:0...
3	user2	password	user2@test.com	750.00	01/01/2026 12:0...

SEGG-U1-P2B_Practica_SQL_Injection.pdf

VulnerableApp Inicio Privacidad

Buscar Usuarios

Busca usuario...

Nombre de usuario **Correo electrónico** **Equilibrio**

Administración	admin@test.com	1000,00 \$
----------------	----------------	------------

VulnerableApp Inicio Privacidad

Buscar Usuarios

Busca usuario...

Nombre de usuario **Correo electrónico** **Equilibrio**

usuario1	user@test.com	500,00 \$
----------	---------------	-----------

VulnerableApp Inicio Privacidad

Buscar Usuarios

Nombre de usuario **Correo electrónico** **Equilibrio**

Administración	admin@test.com	1000,00 \$
usuario1	user@test.com	500,00 \$
usuario2	user2@test.com	750,00 \$

Código vulnerable

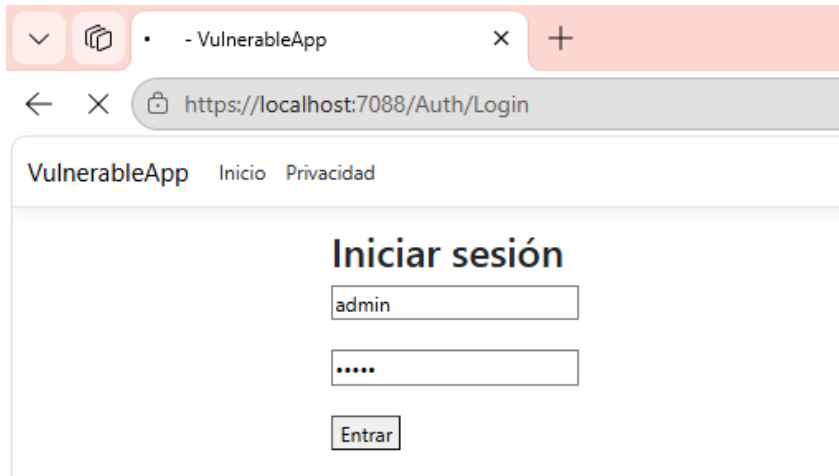
```
0 referencias
public IActionResult Index(string search)
{
    if (string.IsNullOrEmpty(search))
        return View(new List<User>());
    string query = "SELECT * FROM Users WHERE Username LIKE '%" + search + "%'"; var users = _db.Users.FromSqlRaw(query).ToList();
    return View(users);
}
```

Documentar el hallazgo

La vulnerabilidad se encuentra en el método SearchController.Index, donde la consulta SQL se construye mediante concatenación de cadenas utilizando la entrada del usuario. Un atacante puede introducir texto especialmente diseñado para modificar la lógica de la consulta. Al ingresar ' OR '1'='1, la condición puede evaluarse como verdadera para múltiples registros, provocando la exposición de información que no debería mostrarse. Esta vulnerabilidad corresponde a CWE-89 y a la categoría Injection de OWASP.

SEGG-U1-P2C_Practica_Autenticacion.pdf

Admin



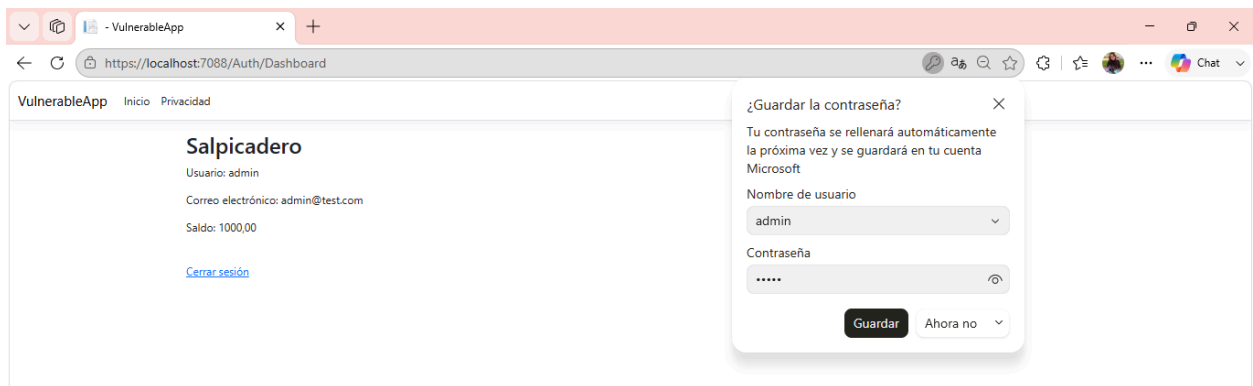
VulnerableApp Inicio Privacidad

Iniciar sesión

admin

.....

Entrar



VulnerableApp Inicio Privacidad

Salpicadero

Usuario: admin

Correo electrónico: admin@test.com

Saldo: 1000,00

[Cerrar sesión](#)

¿Guardar la contraseña?

Tu contraseña se rellenará automáticamente la próxima vez y se guardará en tu cuenta Microsoft

Nombre de usuario

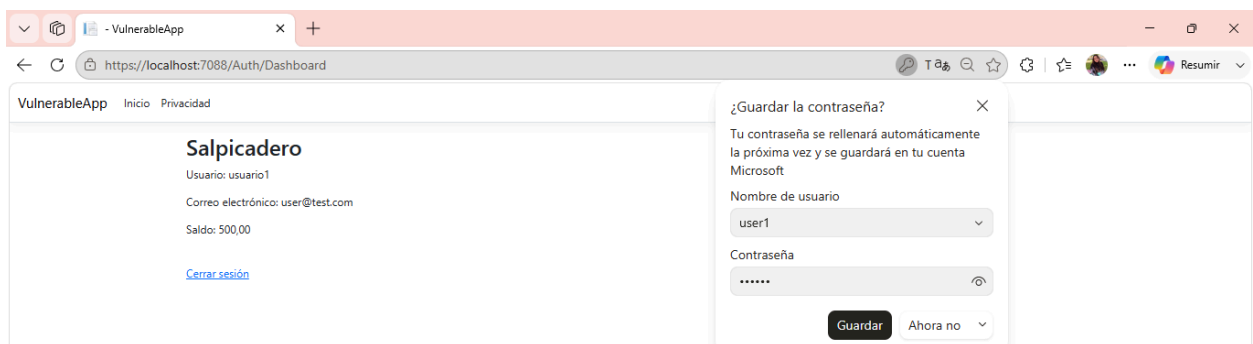
admin

Contraseña

.....

Guardar Ahora no

User1



VulnerableApp Inicio Privacidad

Salpicadero

Usuario: usuario1

Correo electrónico: user@test.com

Saldo: 500,00

[Cerrar sesión](#)

¿Guardar la contraseña?

Tu contraseña se rellenará automáticamente la próxima vez y se guardará en tu cuenta Microsoft

Nombre de usuario

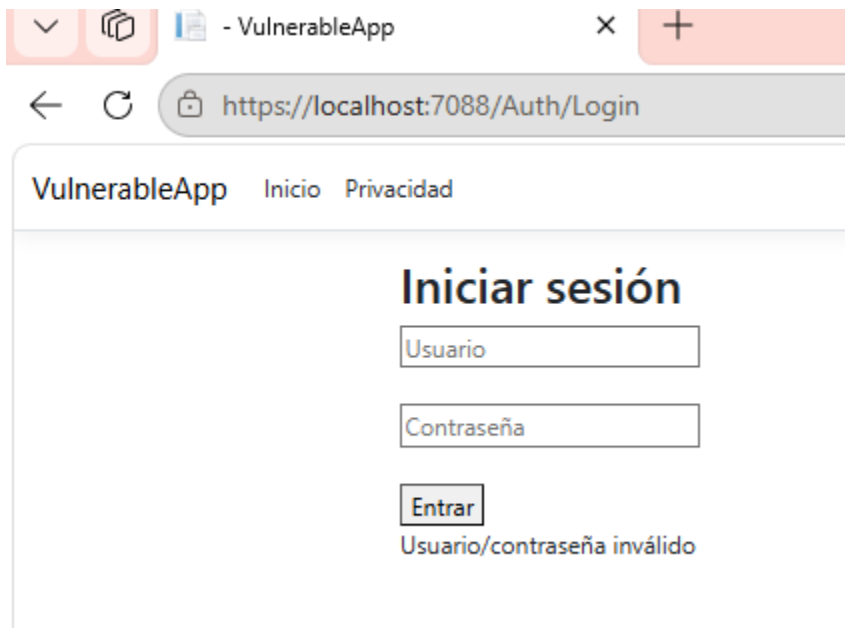
user1

Contraseña

.....

Guardar Ahora no

Usuario no válido:



VulnerableApp Inicio Privacidad

Iniciar sesión

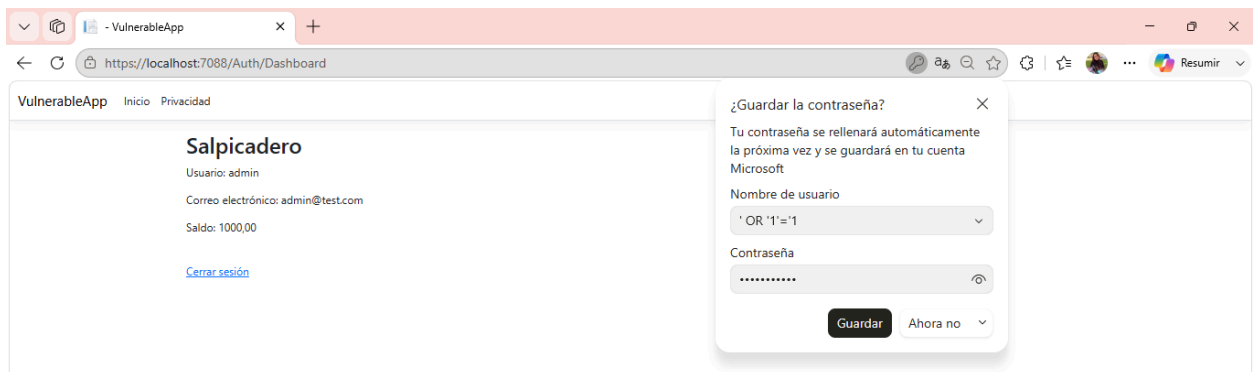
Usuario

Contraseña

Entrar

Usuario/contraseña inválido

código vulnerable.



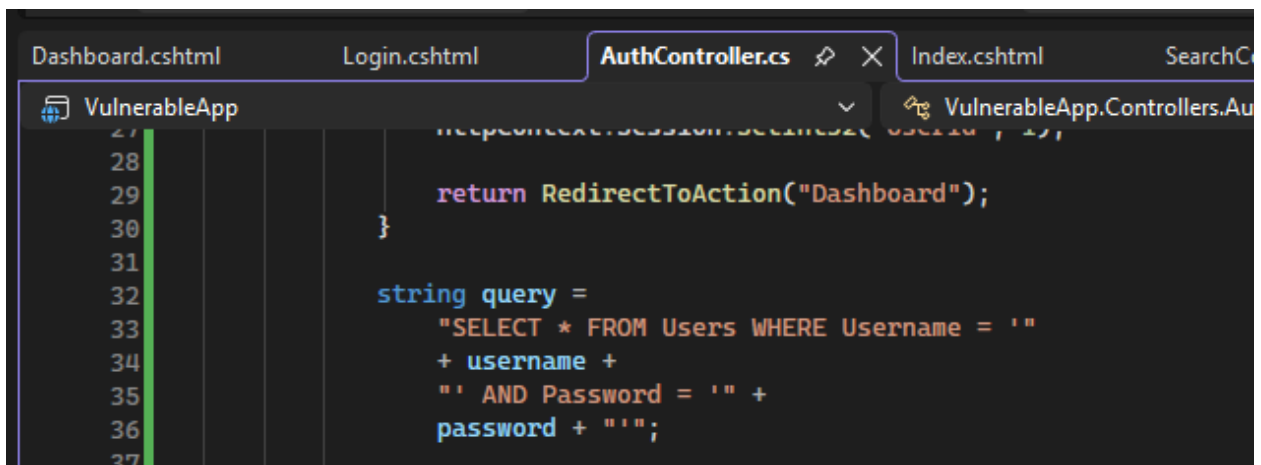
VulnerableApp Inicio Privacidad

Salpicadero

Usuario: admin
Correo electrónico: admin@test.com
Saldo: 1000,00

[Cerrar sesión](#)

¿Guardar la contraseña?
Tu contraseña se rellenará automáticamente la próxima vez y se guardará en tu cuenta Microsoft
Nombre de usuario
OR '1'='1
Contraseña
.....
Guardar Ahora no



```
Dashboard.cshtml Login.cshtml AuthController.cs Index.cshtml SearchC...
VulnerableApp
27
28
29
30
31
32
33
34
35
36
37
return RedirectToAction("Dashboard");
}
string query =
"SELECT * FROM Users WHERE Username = ' "
+ username +
"' AND Password = ' " +
password + "'";
```